

Cloud Hacking Village #5

2025/01/15

きとう

自己紹介

なまえ

- きとう、てきとう、tkito

X ~~Twitter~~: @tkito

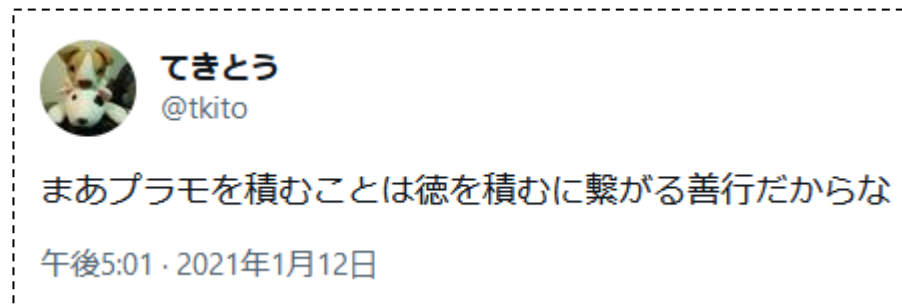


おしごと

- 企業で社内SOCの中の人とかIRとか

しゅみ

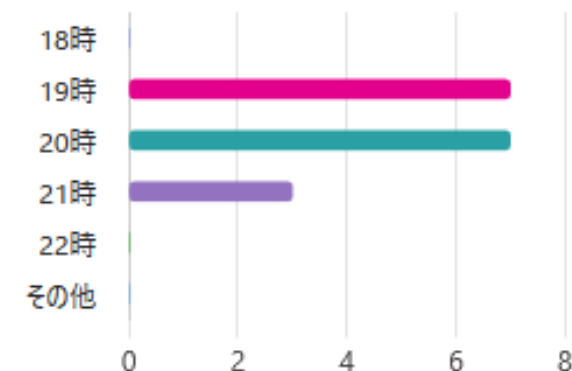
- ゲームしたり海に潜ったり徳を積んだり



Cloud Hacking Village 概要

- 開催日程：毎月第二水曜日 20:00～
 - 月によって前後に調整する場合があります
- 開催形式：Zoom
- クラウド環境のハッキングについて学ぶ勉強会です
- クラウドに関する内容であればなんでもOK
- 攻撃手法だけでなく、防御や検知手法も対象にします
RedとBlueは表裏一体
- どこかで知見をまとめてアウトプットできるといいな
- Offensive Security Lab Japanのオフ会でCTFできるような環境を作りたい

5. 勉強会は何時に開催するのがいいですか？



Cloud Hacking Village の開催形態

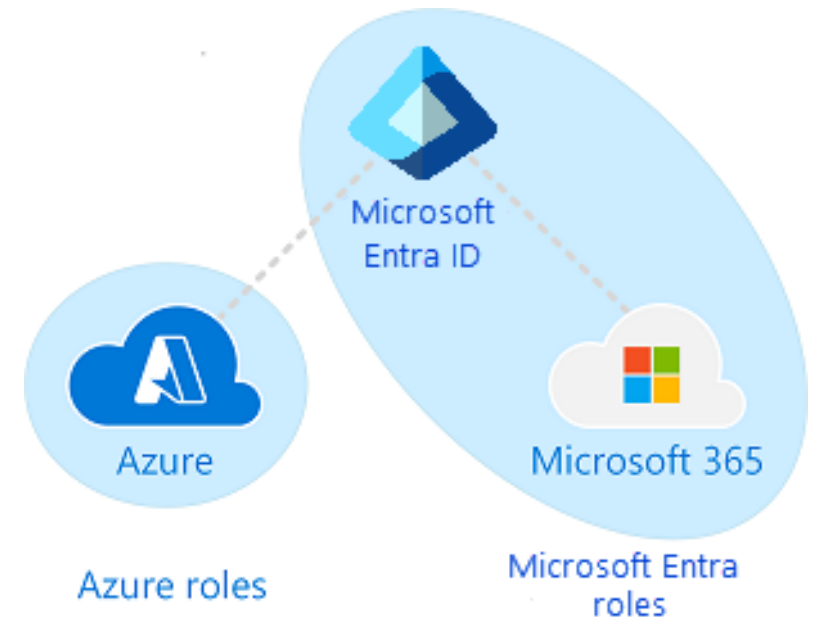
- 参加者でトピックを持ち寄って発表しあう会にしたい
- きとうからはAzureを対象としたハッキングについて毎回発表するようにします
 - 自分の勉強を兼ねているため
 - Azureの基礎、MITRE ATT&CKのCloud Matrix、などからやっていく予定
- クラウドに関するものであれば何でもいいので発表お願いします
 - スライドみたいな形式でまとめてなくてもOK
 - 内容の例：
 - CCSP取ってみた、クラウド環境がやられた事例の紹介、クラウド初めて使ってみた、クラウドプラットフォームごとの仕様の違い、攻撃を実践する環境の作り方、マイナークラウドの紹介、防御手法調べてみた、etc.
- 禁止事項：マサカリ
 - みんな最初は初心者だし、誰だって間違う

Entra IDまとめ

初期侵入から権限昇格まで

Microsoft Entra ID

- Microsoftのクラウドサービスを使う際のID管理基盤
 - Azureだけではない
- 以前はAzure Active Directory (Azure AD)と呼ばれていた
- ユーザーとグループ
- ロールベースのアクセス制御も可能
 - 2種類のロール
 - Microsoftのサービスへのアクセスを制御するためのMicrosoft Entraロール
 - Azureリソースへのアクセス制御をするためのAzureロール



<https://learn.microsoft.com/ja-jp/entra/identity/role-based-access-control/concept-understand-roles>

Azure Threat Research Matrix

この用語を使っていきます

- <https://microsoft.github.io/Azure-Threat-Research-Matrix/>

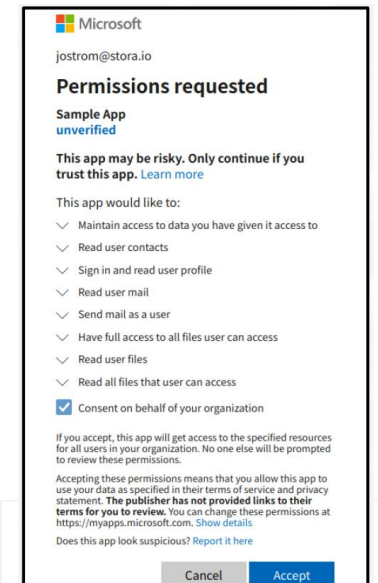
Reconnaissance	Initial Access	Execution	Privilege Escalation	Persistence	Credential Access	Impact
Port Mapping	Valid Credentials	Virtual Machine Scripting	Privileged Identity Management Role	Account Manipulation	Steal Managed Identity JsonWebToken	SAS URI Generation
IP Discovery	Password Spraying	Unmanaged Scripting	Elevated Access Toggle	Account Creation	Steal Service Principal Certificate	File Share Mounting
Public Accessible Resource	Malicious Application Consent	Managed Device Scripting	Local Resource Hijack	HTTP Trigger	Service Principal Secret Reveal	Replication
Gather User Information			Principal Impersonation	Watcher Tasks	Azure KeyVault Dumping	Soft-Delete Recovery
Gather Application Information			Azure AD Application	Scheduled Jobs	Resource Secret Reveal	Azure Backup Delete
Gather Role Information				Network Security Group Modification		
Gather Resource Data				External Entity Access		
Gather Victim Data				Azure Policy		

Hacking Entra ID

- Initial Access
- Reconnaissance
- Privilege Escalation

Initial Access

- Valid Credentials
 - アカウントのパスワードを既に知っている状態
 - 過去の回でアカウント渡してAzure Portalにアクセスしてもらったのはこの手法
- Password Spraying
 - パスワードクラックの一手法
 - 別にSprayingに限らずBrute forceやPassword list attackもあるのに載せてないのはなぜか不明
- Malicious Consent Application
 - ユーザにアプリケーションへのアクセス権委譲を"同意"させアクセス権を取得する
 - Xのアプリ同意画面と同じようなもの



Reconnaissance

※ Entra IDに関連するもののみ

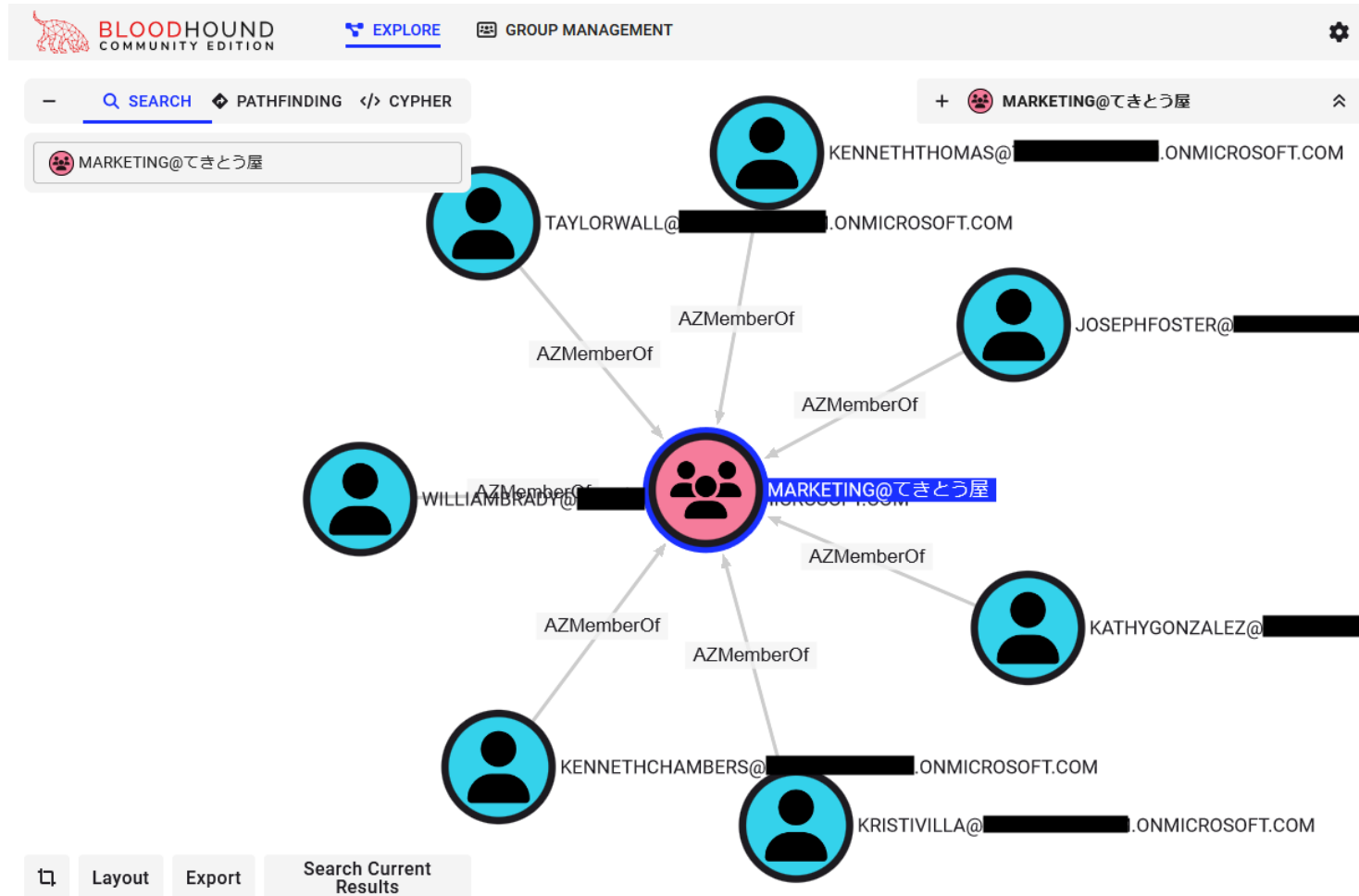
- Gather User Information
 - ユーザの情報を収集する
- Gather Application Information
 - 登録されているアプリの情報を収集する
- Gather Role Information
 - ロールの一覧、ロールが割り当てられているユーザの情報を収集する
- Gather Victim Data
 - アクセスに使っているユーザの情報を収集する

Reconnaissance using AzureHound

- AzureHound
 - <https://github.com/BloodHoundAD/AzureHound>
 - Entra IDの情報を自動的に収集する
 - 得られた情報をBloodHoundに入力して分析する
 - 実行時に与えたユーザが確認できる範囲の情報のみになるので、高権限を得た場合には再度情報を取得しなおすことで新たなパスが見つかる可能性がある

Reconnaissance using AzureHound

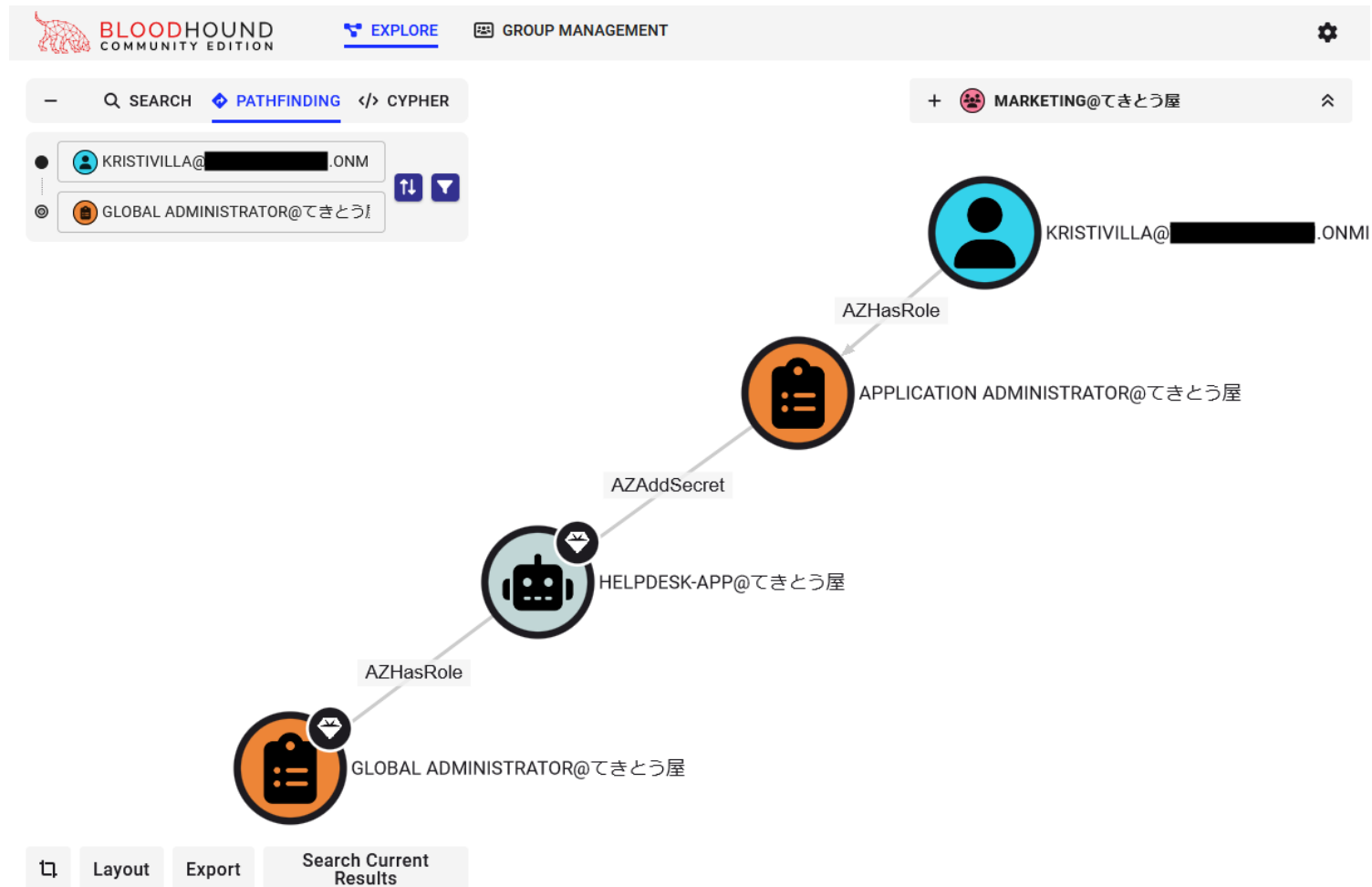
BloodHoundで見てみたところ



Privilege Escalation

- Privileged Identity Management Role
- Elevated Access Toggle
- Local Resource Hijack
- Principal Impersonation
- Azure AD Application
 - 過去の回でやったのはこれ

Privilege Escalation using AzureHound



Privilege Escalation via Azure AD Application

- Global Administratorのロールを持つアプリAが存在
- ユーザXはApplication Administratorのロールを持つ
- 攻撃者は現在ユーザXとしてサインインしている

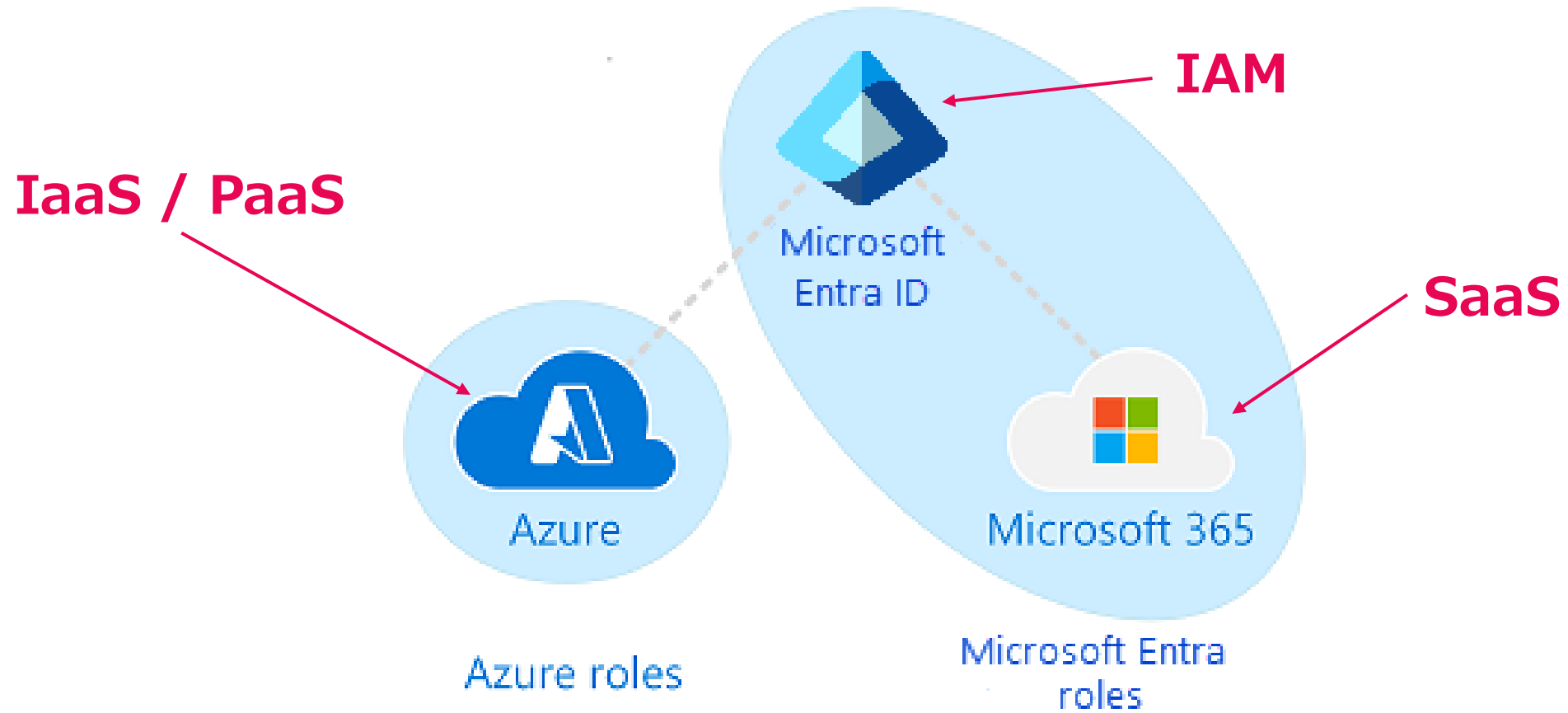


1. ユーザXのApplication Administratorの権限を使って、アプリAに新たな認証情報を追加する
2. これによりアプリAとしてサインイン可能に
3. アプリAはGlobal Administratorのロールを持っているため、攻撃者がその権限を持つことができた

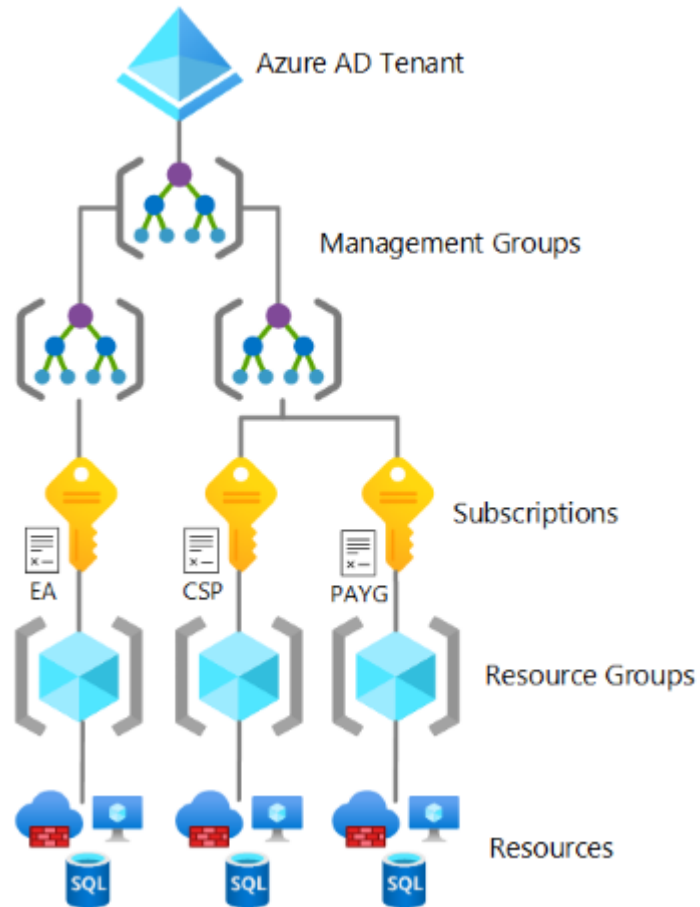
Azure Hacking - Storage -

倉庫番

Azure (IaaS / PaaS)



Azure用語



テナント：Azureを管理する一番大きなグループ
1組織で1つ

管理グループ：複数のサブスクリプションをまとめるグループ

サブスクリプション：Azure 内での管理、課金、スケールの単位

<https://learn.microsoft.com/ja-jp/azure/cloud-adoption-framework/ready/landing-zone/design-area/resource-org-subscriptions>

リソースグループ：複数のリソースをまとめたグループ

リソース：VMやネットワーク、DBなどのサービスのインスタンス

<https://learn.microsoft.com/ja-jp/azure/cloud-adoption-framework/ready/landing-zone/design-area/azure-billing-ad-tenant>

Azure Storage

いろいろなストレージを提供

- <https://azure.microsoft.com/ja-jp/products/category/storage/>
- Azure Blob Storage
 - オブジェクトストレージ（ファイル格納）
- Azure Files
 - ファイルサーバ（SMB）を提供
- Azure Queue Storage
 - メッセージを格納
- Azure Table Storage
 - NoSQL
- 他にもある

Storage Account

- Azure Storageの管理単位
- 各サービスはStorage Accountに紐づけられて利用される
- "Account"という名前だが、ユーザアカウントなどとは異なり、リソースの一種として扱われる

ホーム > ストレージ アカウント >

ストレージ アカウントを作成する ...

基本情報 詳細 ネットワーク データ保護 暗号化 タグ レビューと作成

Azure Storage は、高可用性、セキュリティ、耐久性、スケーラビリティ、冗長性を備えたクラウド ストレージを提供する Microsoft が管理するサービスです。Azure Storage には、Azure BLOB (オブジェクト)、Azure Data Lake Storage Gen2、Azure Files、Azure Queues、Azure Tables が含まれます。ストレージ アカウントのコストは、使用量と、下で選ぶオプションに応じて決まります。 [Azure ストレージ アカウントの詳細](#)

プロジェクトの詳細

新しいストレージ アカウントを作成するサブスクリプションを選択します。ストレージ アカウントを他のリソースと一緒に整理して管理するには、新規または既存のリソース グループを選択します。

サブスクリプション * Azure サブスクリプション 1

リソース グループ * tkitochvtest
[新規作成](#)

ホーム > リソース グループ >

tkitochvtest リソース グループ

検索

+ 作成 ビューの管理 リソース グループの削除 更新 CSV にエクスポート クエリを開く タグの割り当て 移動

概要

▼ 基本 JSON ビュー

リソース 推奨事項

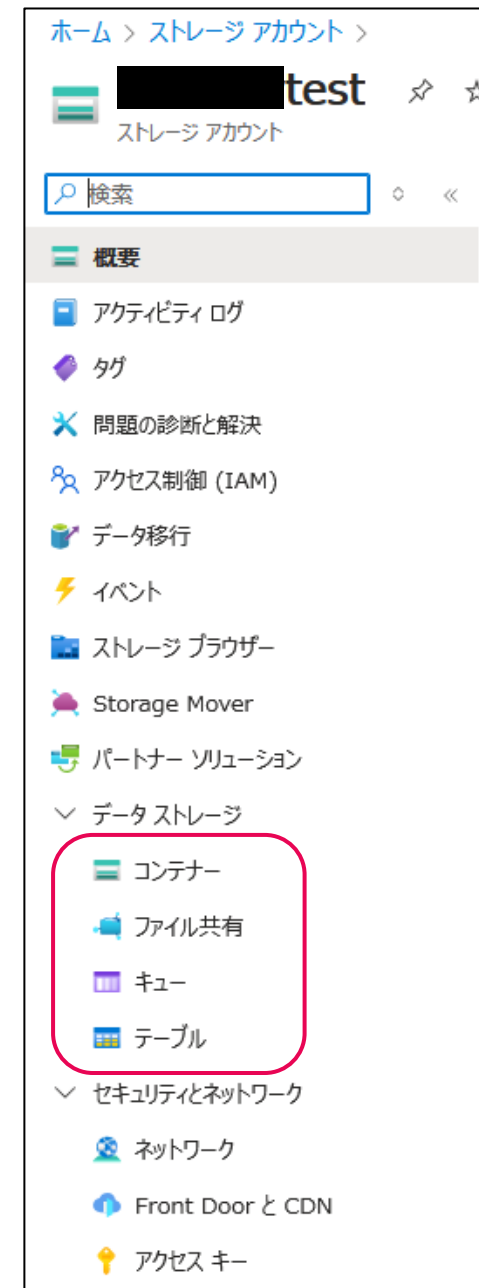
任意のフィールドのフィルター... 種類 次の値と等しい すべて × 場所 次の値と等しい すべて × フィルターを追加

2 件中 1 ~ 2 件のレコードを表示しています。 ☐ 非表示の型の表示 ① グループ化なし ≡ リスト ビュー

☐ 名前 ↑↓	種類 ↑↓	場所 ↑↓	
☐ test	キー コンテナー	Japan East	...
☐ test	ストレージ アカウント	Japan East	...

Storage Account

- ストレージアカウントに各サービスの利用が紐づけられる
 - "コンテナ"はBlob Storageのファイル管理単位



Azure Blob Storage

- オブジェクトストレージ
- ファイル格納場所
- コンテナという単位でファイルを管理する（フォルダみたいなもの）
- アクセス用のエンドポイント

```
https://<storage-account>.blob.core.windows.net/<container>/<file>
```

- ストレージアカウント、コンテナ、ファイルがわかればアクセスできる
- 逆に言うと、ファイルを示したURLが1つあればストレージアカウントとコンテナ名がわかる

コンテナのアクセスレベル

- プライベート
 - 匿名アクセス不可
- BLOB
 - ファイル名を指定しての匿名アクセスが可能（コンテナ内のファイル一覧の確認は不可）
- コンテナ
 - ファイル一覧含めて匿名アクセスが可能

名前	最終変更日時	匿名アクセスレベル
☐ \$logs	2025/1/15 18:28:22	プライベート
☐ \$web	2025/1/15 18:28:22	プライベート
☐ container1	2025/1/15 18:10:11	BLOB
☐ container2	2025/1/15 18:10:11	コンテナ
☐ container3	2025/1/15 18:10:11	プライベート

アクセスレベルの確認

- どのコンテナにも"chv.png"というファイルが配置されている

```
https://*****.blob.core.windows.net/container1/chv.png
```

```
https://*****.blob.core.windows.net/container2/chv.png
```

```
https://*****.blob.core.windows.net/container3/chv.png
```


ファイル一覧の確認

- "?restype=container&comp=list"をコンテナ名の後に付けるとファイルリストを表示

```
https://*****.blob.core.windows.net/container2?restype=container&comp=list
```

- コンテナを変えるとどうなる？

Blob Storage Hacking

- "?restype=container&comp=list"をつけて意図せぬ公開ファイルを調査
- ファイル名を総当たり
- コンテナ名を総当たり
- ストレージアカウントを総当たり
- ツールを使う（詳細未調査）
 - BlobHunter: <https://github.com/cyberark/blobhunter>
 - GrayHat Warfare: <https://buckets.grayhatwarfare.com/>
 - goblob: <https://github.com/Macmod/goblob>

次回

- Cloud Hacking Village #6
- 日程：2025/02/12(水) 20:00～
- 内容：
 - Azureネタ：ストレージ（続き） and/or マネージドID
 - その他皆さんの持ち寄りネタ

おしまい

きとう



@tkito

